GRC103 Risk Assessment and Management Techniques

Technical Risk Treatment Lab

Student Name: Faith Mathapelo Letsoara

Registration number: C11/26/CGRC/17582

Cohort /Batch: Cohort 11

Instructor Name: Ene

Date of Submission: 08/11/2026

Introduction

The purpose of this lab was to identify technical risks within a small Linux-based web environment and apply appropriate risk treatment strategies. The exercise involved building and testing a web server, identifying weaknesses, implementing controls, validating their effectiveness, and documenting the remaining residual risk.

The environment consisted of an Ubuntu Server virtual machine hosting a simple web portal and a Kali Linux virtual machine intended to perform validation testing. Several risks were identified during baseline assessment, including an exposed legacy service, publicly accessible archived data, insufficient network restrictions, and the absence of a tested recovery process.

The selected treatments included avoidance, mitigation, transfer, and acceptance, with validation performed after each change to confirm that the intended risk reduction had been achieved.

Environment Overview

The practical environment consisted of the following components:

- Ubuntu Server 24.04 LTS
- Kali Linux
- NGINX Web Server
- UFW Firewall
- Oracle VirtualBox

The Ubuntu server was assigned the following address: **10.0.2.15**

A web portal named **Northbridge Services Portal** was hosted on the server together with a deliberately exposed archive directory and a legacy application listening on TCP port 8080.

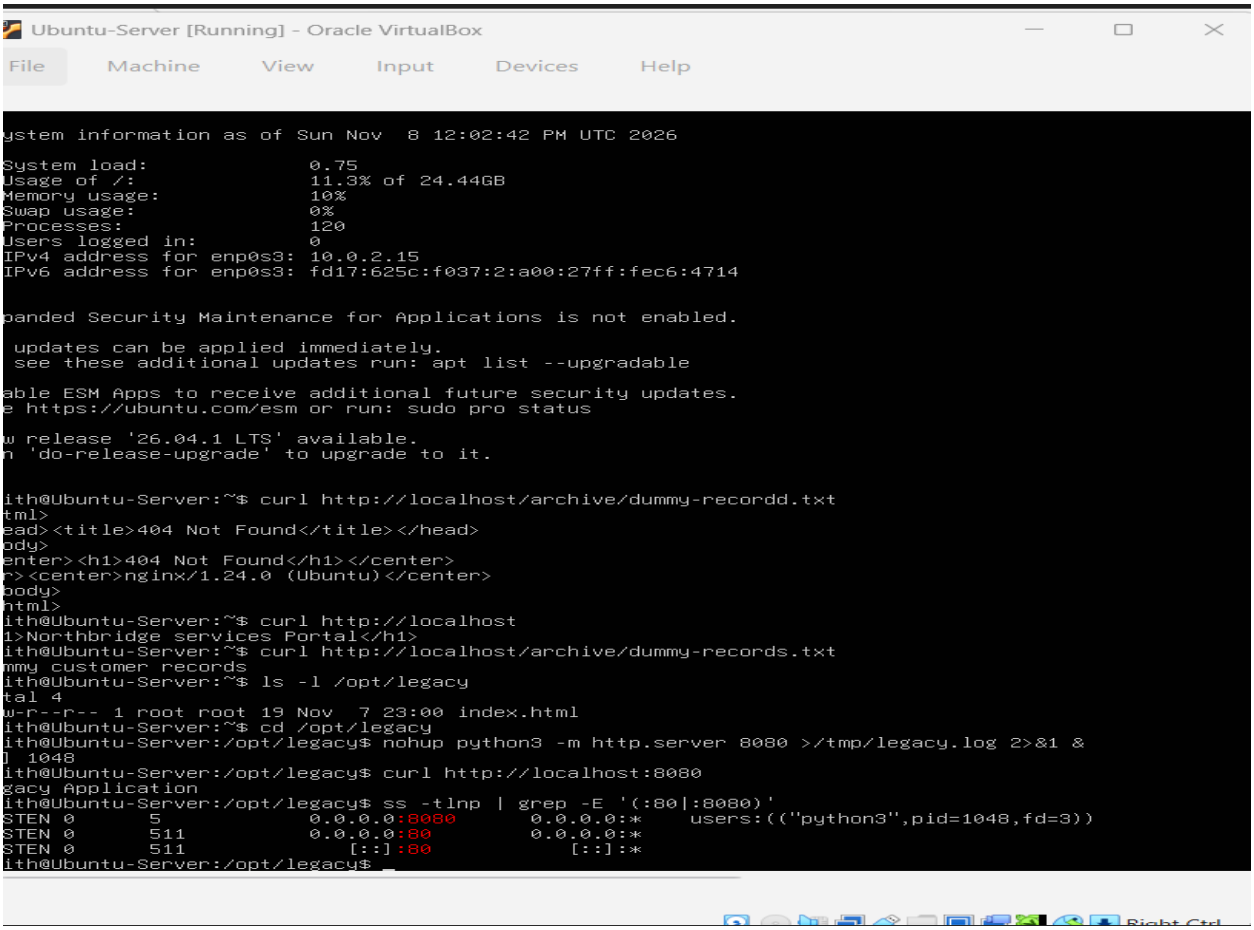
Baseline Assessment

Before any changes were made, the environment was assessed to establish the current level of risk exposure.

Testing confirmed that:

- The Northbridge Services Portal was accessible over HTTP on port 80.
- The archive directory could be accessed directly through the web server.
- A legacy application was accessible on TCP port 8080.
- No meaningful restriction of inbound access had been verified.
- Recovery procedures had not yet been tested.

The baseline assessment demonstrated that sensitive content was unnecessarily exposed and that multiple attack surfaces existed within the environment.



Baseline Validation

Risk Register

Four primary risks were identified during the assessment.

Risk ID	Description	Likelihood	Impact	Risk Score	Treatment
R1	Legacy service exposed on TCP 8080	4	3	12	Avoidance
R2	Archived records publicly accessible	4	4	16	Mitigation
R3	Insufficient network access controls	3	4	12	Mitigation
R4	Loss of portal content due to failure or deletion	3	4	12	Mitigation

The archive exposure represented the highest risk because sensitive information could be viewed directly through the web server.

Risk Treatment Activities

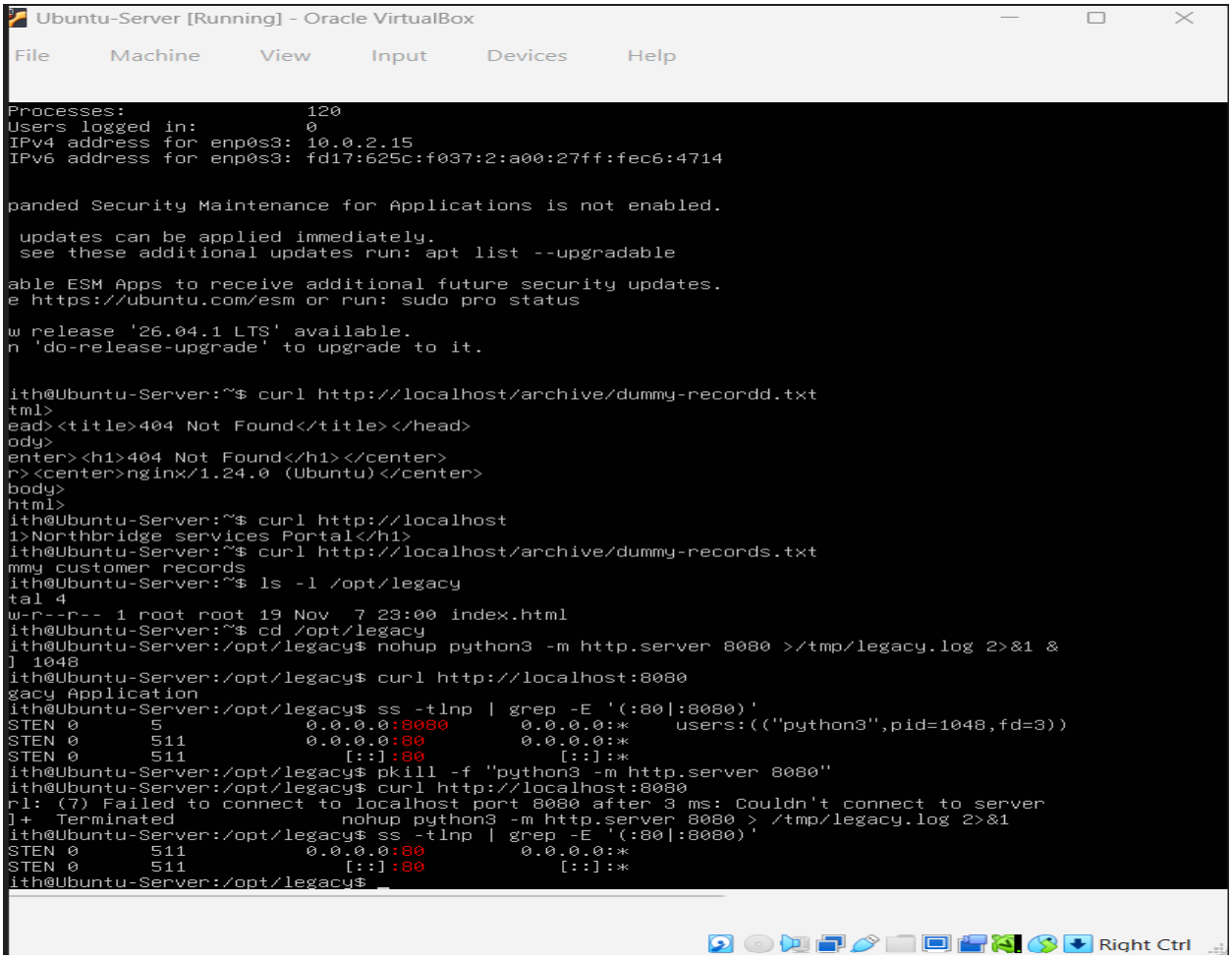
5.1 Avoidance - Legacy Service Removal

During baseline testing, a legacy Python-based application was found listening on TCP port 8080. The service was not required for the operation of the Northbridge Services Portal and therefore represented unnecessary exposure.

Rather than attempting to secure or maintain the service, an avoidance strategy was selected. The service was stopped and removed from operation.

Validation was performed after the change. Connection attempts to port 8080 were unsuccessful, confirming that the legacy application was no longer accessible.

This treatment eliminated the associated exposure while having no impact on the primary portal.



Legacy Service Removed

Rollback Plan

If the service were required in future, it could be restarted from the original application directory and returned to operation.

5.2 Mitigation - Archive Hardening

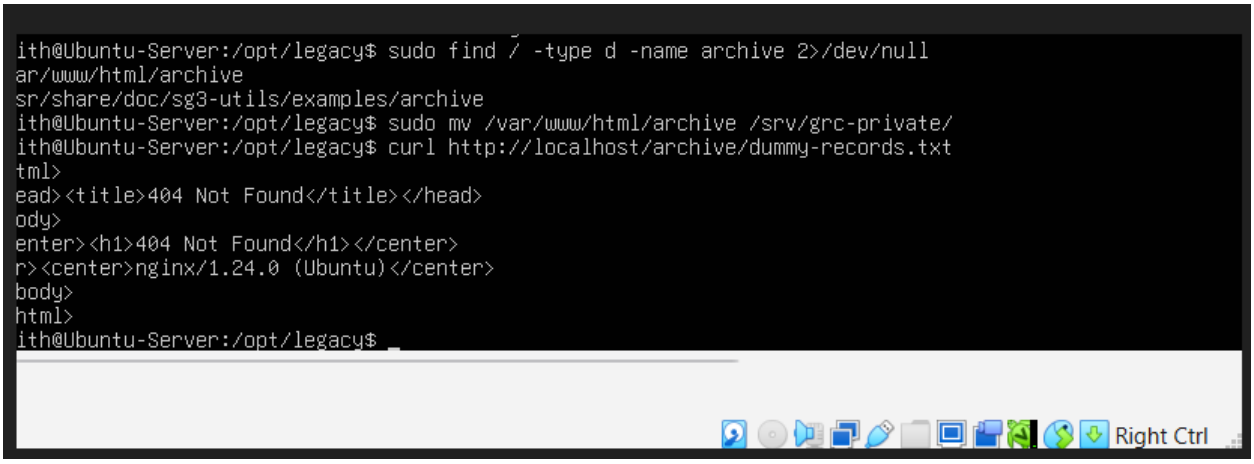
The baseline assessment revealed that archived records could be accessed directly through the web server. Although the files used in the lab contained fictional information, the configuration reflected a common real-world security weakness.

To reduce the risk of information disclosure, the archive directory was moved from: /var/www/html/archive to: /srv/grc-private

This location is outside the web root and cannot be accessed through normal HTTP requests.

After the change was implemented, attempts to access the archive returned a 404 Not Found response.

The successful validation demonstrated that archived records were no longer exposed through the public web service.



Archive Hardened

Mitigation - Firewall Configuration

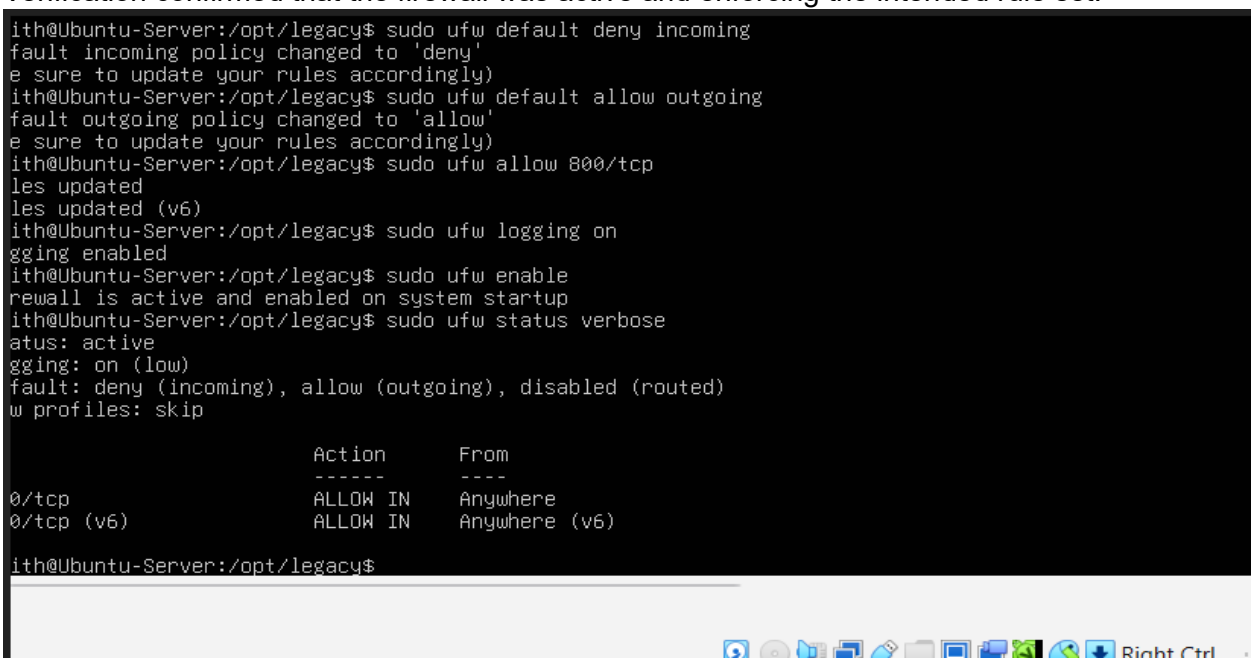
Network access restrictions were improved through the implementation of UFW.

The firewall was configured to:

- Deny incoming connections by default
- Permit outgoing connections
- Allow HTTP traffic on TCP port 80
- Enable logging for monitoring purposes

These settings reduced the attack surface while ensuring that legitimate access to the portal remained available.

Verification confirmed that the firewall was active and enforcing the intended rule set.



UFW Configuration

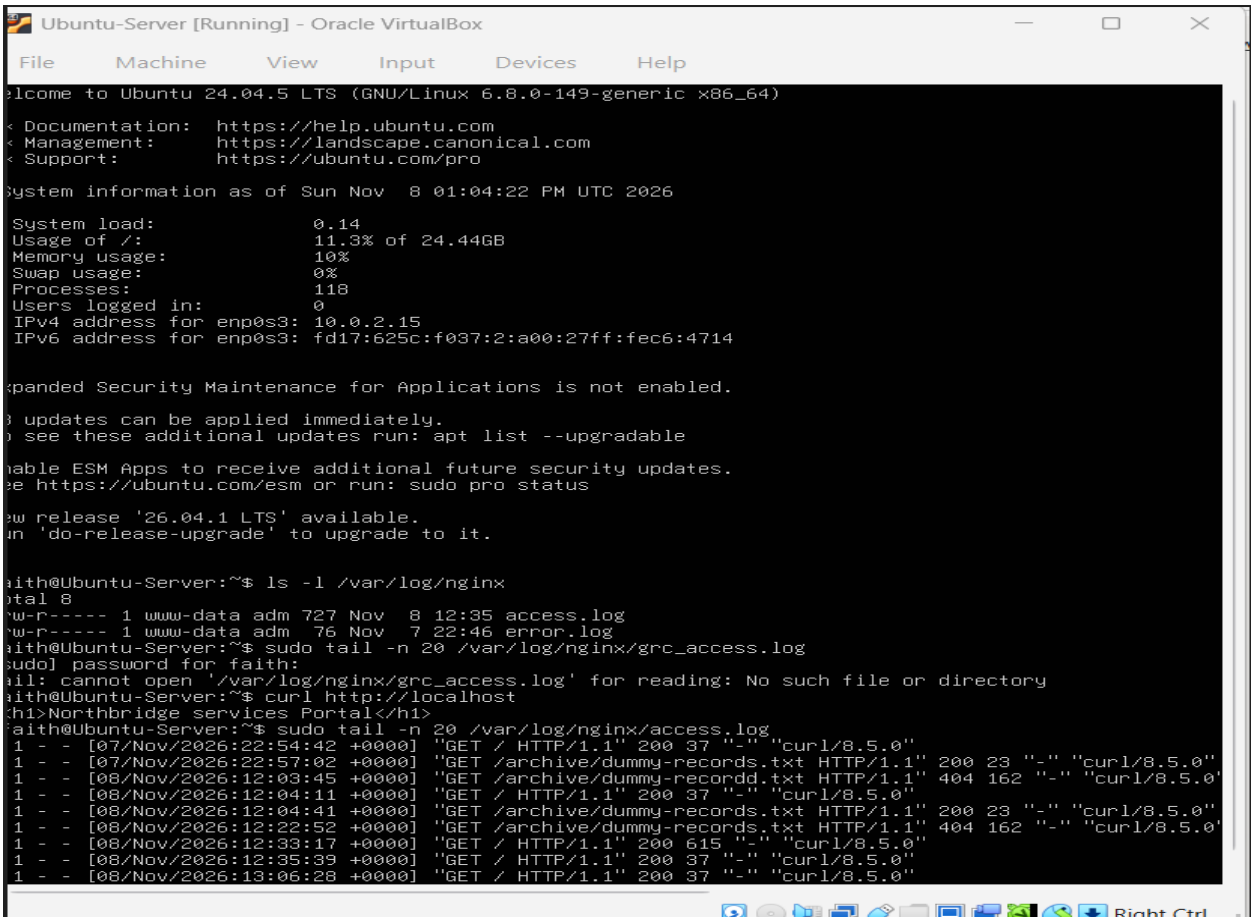
Logging Validation

Monitoring and auditing are important components of risk management because they provide visibility into system activity and attempted access.

To verify logging functionality, the web portal was accessed and the NGINX access logs were reviewed.

The logs recorded successful requests to the home page as well as previous requests made to the archive directory. This demonstrated that access attempts were being captured correctly and could be reviewed for investigative or auditing purposes.

The validation confirmed that monitoring controls were functioning as expected.



NGINX Access Log

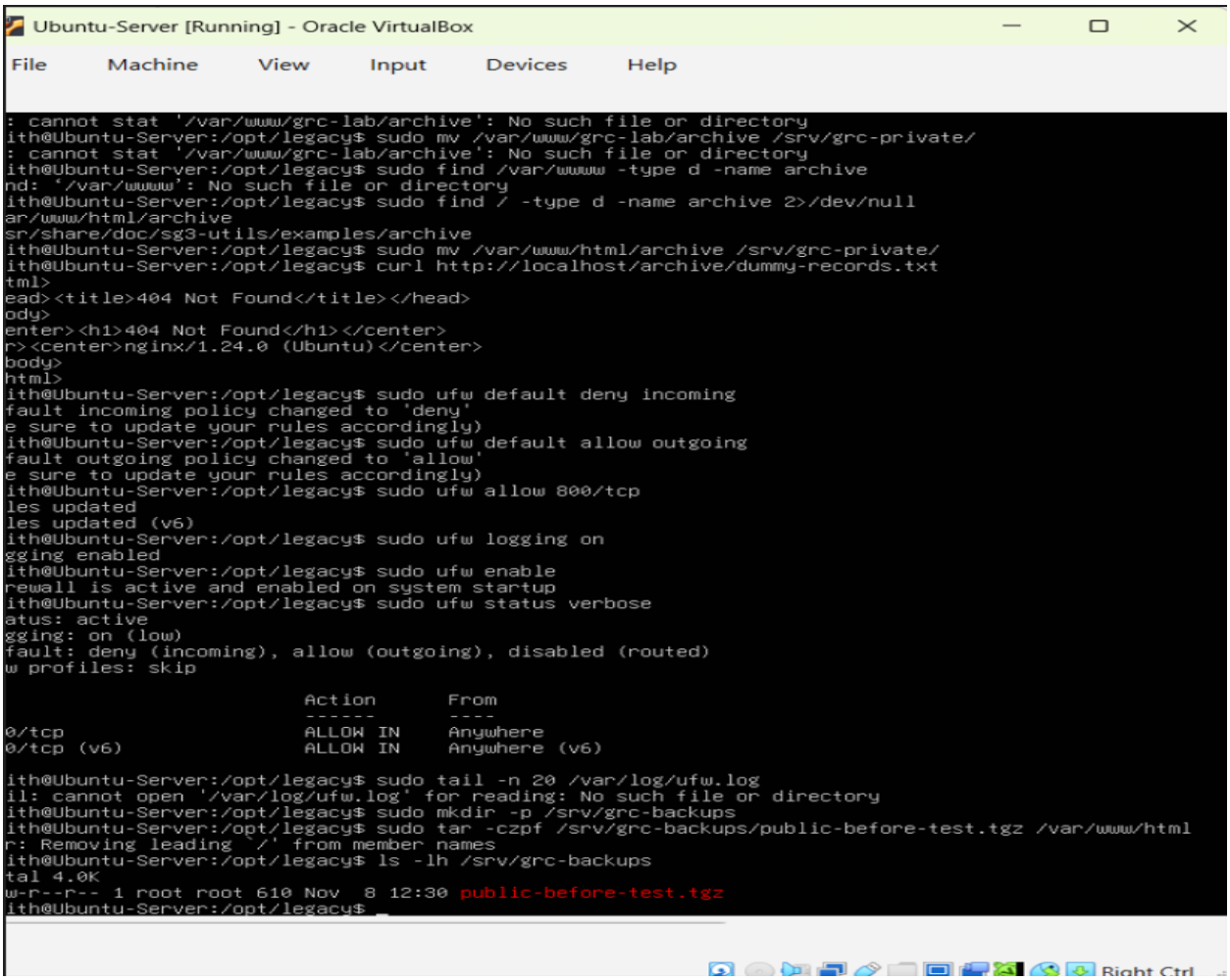
Backup and Recovery Testing

Backup Creation

Business continuity depends on the ability to recover critical information following accidental deletion or system failure.

A backup archive of the web content was created and stored as: public-before-test.tgz

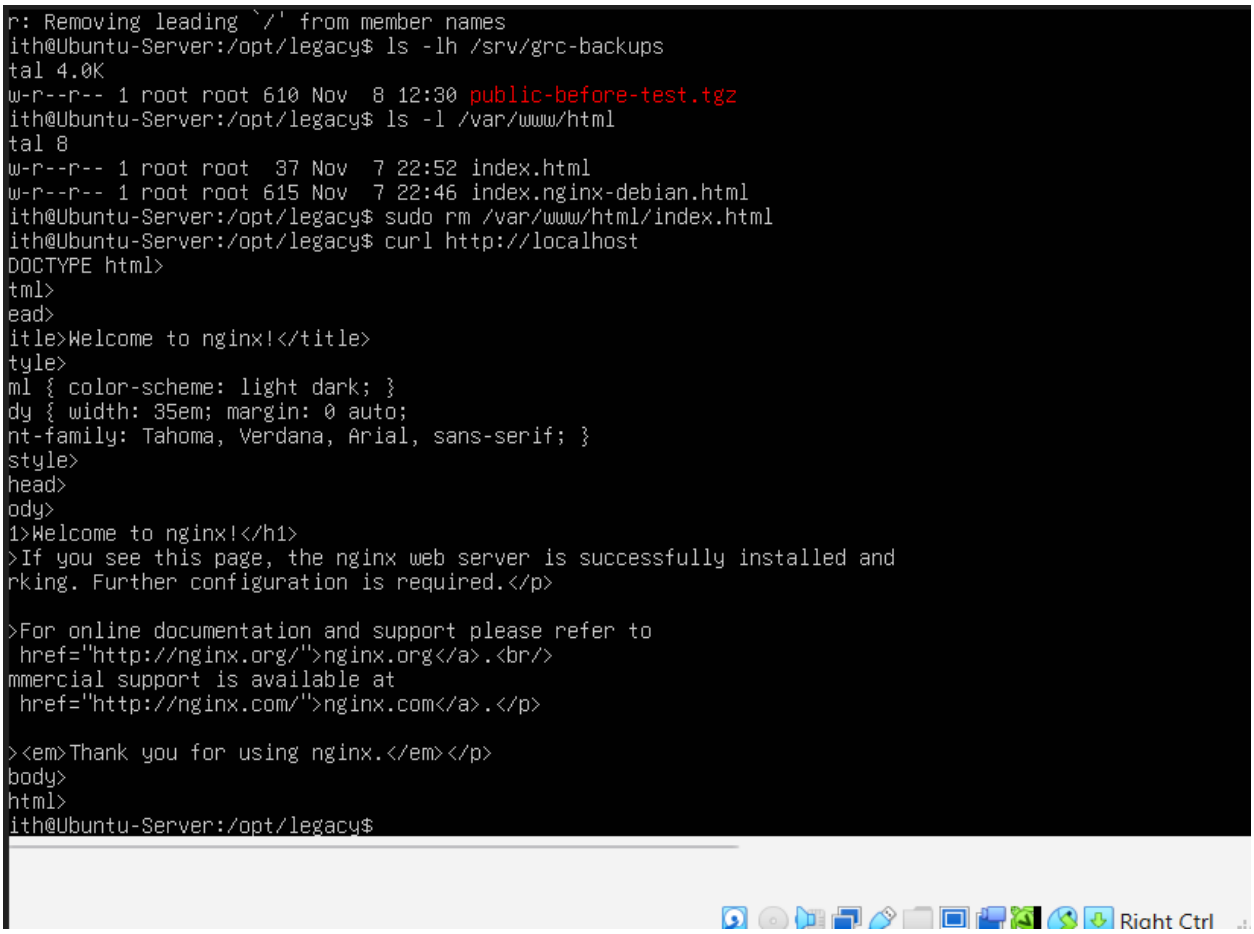
The backup file was verified after creation to ensure it was available for recovery.



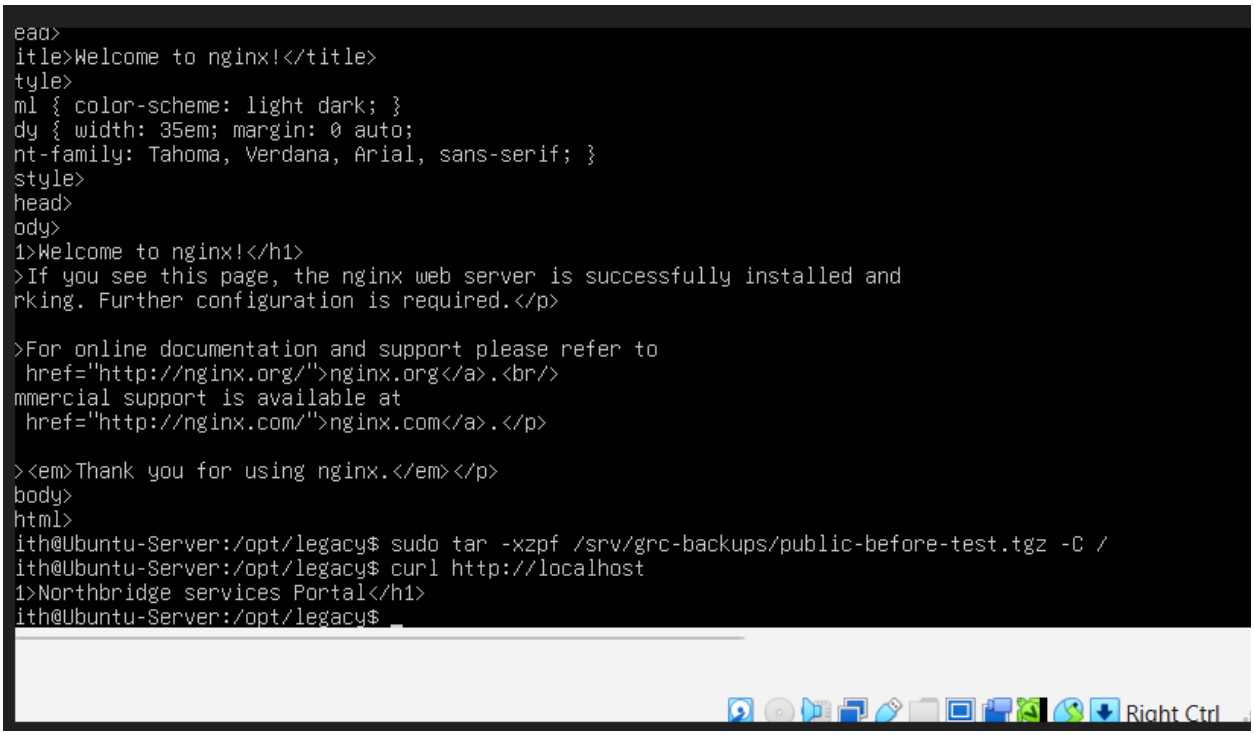
Evidence Backup Created.

Recovery Validation

To validate the effectiveness of the backup, a recovery exercise was performed.
The portal home page was deliberately deleted from the server. Immediately afterward, access to the site returned the default NGINX page rather than the Northbridge Services Portal.
This demonstrated that the portal content was no longer available.
The backup archive was then restored, and the portal was tested again.
Following restoration, the original portal page reappeared successfully.
This exercise confirmed that the backup process was capable of restoring service after content loss.



Portal Removed Before Restore



Recovery Success.

Transfer Strategy

A transfer strategy was considered for backup and recovery services.

Under this approach, backup infrastructure and storage responsibilities would be assigned to a third-party service provider. The customer would remain responsible for validating backups, approving recovery activities, and ensuring the integrity of application data.

While the transfer of operational responsibility can reduce organizational workload, it does not eliminate all risk. Responsibility for business data ultimately remains with the system owner.

Risk Acceptance

Some residual risk remained after treatment.

The portal continued to operate using HTTP because the environment was isolated and used only fictional information for testing purposes.

The remaining exposure was considered acceptable within the context of a controlled laboratory environment.

This acceptance decision would require review if:

- Real organizational information were added.
- Internet connectivity were introduced.
- The environment were transitioned to production use.

Cost Analysis
Three risk treatment options were evaluated

Hardening

Item	Cost
Implementation Labour	**$100**
Maintenance	**$50**
Total	**$150**

Managed Backup Service

Item	Cost
Initial setup	**$120**
Annual Subscription	**$240**
Total	**$360**

TLS Deployment

Item	Cost
Deployment	**$75**
Maintenance	**$25**
Total	**$100**

This approach provides meaningful risk reduction while remaining the most cost-effective solution**.**

Based on the analysis, the recommended approach is a combination of Hardening and TLS Deployment with a combined first-year cost of $250. This option provides effective risk reduction while remaining more cost-effective than the managed backup service alternative.

Annualized Loss Expectancy (ALE)
The assignment provided an estimated loss value of $5,000 together with an annual occurrence rate of 0.2.
Baseline ALE:
ALE = 0.2 x $5000
ALE = $1000

Following implementation of the recovery control, the potential loss value was assumed to decrease to $1,000.

Revised ALE:
ALE = 0.2 x $1000
ALE = $200

Annual risk reduction:
$1,000 − $200 = $800

Management Summary

A technical risk assessment and treatment exercise was conducted on an Ubuntu-based web environment hosting the Northbridge Services Portal. Baseline testing identified several weaknesses, including an exposed legacy service, publicly accessible archive data, limited access controls, and an untested recovery process.

Risk treatment activities focused on reducing unnecessary exposure while maintaining service availability. The legacy service was removed, archived data was relocated outside the web root, firewall protections were implemented, logging capabilities were verified, and backup recovery procedures were successfully tested.

Validation activities confirmed that the implemented controls were effective. The legacy application was no longer accessible, archive content could not be reached through the web server, firewall controls were active, logging was operational, and deleted portal content was successfully restored from backup.
Although some residual risk remains due to the use of HTTP, the risk level is considered acceptable within the isolated laboratory environment. Overall, the implemented controls significantly reduced the identified risks and improved the security and resilience of the system.

Conclusion

The lab successfully demonstrated the practical application of risk treatment strategies within a Linux web-server environment. Identified risks were reduced through avoidance and mitigation controls, while backup and recovery testing confirmed continuity capabilities. Validation activities showed measurable risk reduction and improved system resilience. The remaining residual risks were documented and accepted within the scope of the isolated laboratory environment.